



中华人民共和国认证认可行业标准

RB/T 182—2023

移动智能终端应用软件个人信息安全 评价规范

Evaluation specifications for personal information security of application software
in smart mobile terminals

2024-05-20 发布

2024-07-01 实施

国家认证认可监督管理委员会 发布
中国标准出版社 出版

目 次

前言 III

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 评价流程 2

 4.1 概述 2

 4.2 评价主要环节 3

5 评价要求 4

 5.1 组建团队 4

 5.2 制定方案 4

 5.3 实施评价 5

 5.4 结果记录 5

6 评价内容及方法 5

 6.1 个人信息的收集 5

 6.2 个人信息的存储 10

 6.3 个人信息的使用 13

 6.4 个人信息主体的权利 17

 6.5 个人信息的委托处理、共享、转让、公开披露 22

 6.6 个人信息安全事件处置 31

 6.7 组织的个人信息安全管理要求 32

7 评价结果判定 38

 7.1 文档审核结果 38

 7.2 技术验证结果判定 38

 7.3 现场审核结果判定 38

 7.4 认证决定 39

附录 A（规范性） 移动智能终端应用软件个人信息安全评价内容 40

附录 B（资料性） 评价项编码规则说明 45

参考文献 47

前 言

本文件按照 GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文的发布机构不承担识别专利的责任。

本文件由国家认证认可监督管理委员会提出并归口。

本文件起草单位：中国网络安全审查认证和市场监管大数据中心、北京软件产品质量检测检验中心、上海市信息安全测评认证中心、中国电子科技集团公司第十五研究所、中国信息通信研究院、公安部第一研究所、北京邮电大学、中国科学院软件研究所。

本文件主要起草人：张晓梅、许静慧、辛建峰、王威、顾敏、胡石、袁翠红、陈淑娟、田晴云、何静、温岩莉、郝伟博、王艳红、任凤丽、韩煜、冀乃杰、苏璞睿、张淼、严妍、王也。

移动智能终端应用软件个人信息安全 评价规范

1 范围

本文件规定了移动智能终端应用软件个人信息安全的评价流程、评价要求、评价内容及方法和评价结果判定。

本文件适用于认证机构和技术验证机构对移动智能终端应用软件个人信息安全进行检测、评估和认证等活动。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中,注日期的引用文件,仅该日期对应的版本适用于本文件;不注日期的引用文件,其最新版本(包括所有的修改单)适用于本文件。

GB/T 35273—2020 信息安全技术 个人信息安全规范

3 术语和定义

GB/T 35273—2020 界定的以及下列术语和定义适用于本文件。

3.1

移动智能终端应用软件 application software in smart mobile terminal

针对移动智能终端开发的应用软件,包括移动智能终端预置的第三方应用软件,以及互联网服务提供者提供的通过网站、应用商店等移动应用分发平台下载、安装和升级的应用软件。

注:简称“App”。

[来源:GB/T 34975—2017,3.3,有修改]

3.2

认证机构 certification body

从事与产品、服务、过程、体系或人员有关的第三方证明活动的机构。

注:认证机构可以自己进行测试和检验活动,或者委托其他机构代表其进行这些活动。

[来源:RB/T 072—2021,4.6]

3.3

运营机构 operating organization

通过移动智能终端应用软件向用户提供信息服务的网络运营者,负责移动智能终端应用软件的运营,承担移动智能终端应用软件个人信息安全的法律责任。

3.4

技术验证 technical verification

专业技术人员采用测试、检查和文档核查等方法进行符合性验证的过程。

3.5

技术验证机构 technical verification organization

通过测试、检查和文档核查等方法对技术性要求的符合性开展验证活动的机构。

3.6

个人信息 personal information

以电子或者其他方式记录的能够单独或者与其他信息结合识别特定自然人身份或者反映特定自然人活动情况的各种信息。

[来源:GB/T 35273—2020,3.1]

3.7

个人敏感信息 personal sensitive information

一旦泄露、非法提供或滥用可能危害人身和财产安全,极易导致个人名誉、身心健康受到损害或歧视性待遇等的个人信息。

[来源:GB/T 35273—2020,3.2]

3.8

个人信息主体 personal information subject

个人信息所标识或者关联的自然人。

[来源:GB/T 35273—2020,3.3]

3.9

个人信息控制者 personal information controller

有能力决定个人信息处理目的、方式等的组织或个人。

[来源:GB/T 35273—2020,3.4]

4 评价流程

4.1 概述

移动智能终端应用软件个人信息安全认证评价流程主要分为四个阶段:

- a) 申请受理阶段:认证机构接收到运营机构提交的申请资料并初步审核通过后受理认证申请;
- b) 技术验证阶段:认证机构安排技术验证机构开展技术验证环节;
- c) 现场审核阶段:认证机构收到技术验证报告并审查合格后,在规定时间内组织审核人员进行现场审核;
- d) 认证决定阶段:认证机构根据申请资料、技术验证结论和现场审核结论等进行综合评价,做出认证决定。认证决定通过后,由认证机构向运营机构颁发认证证书。

图 1 给出了具体的评价流程。

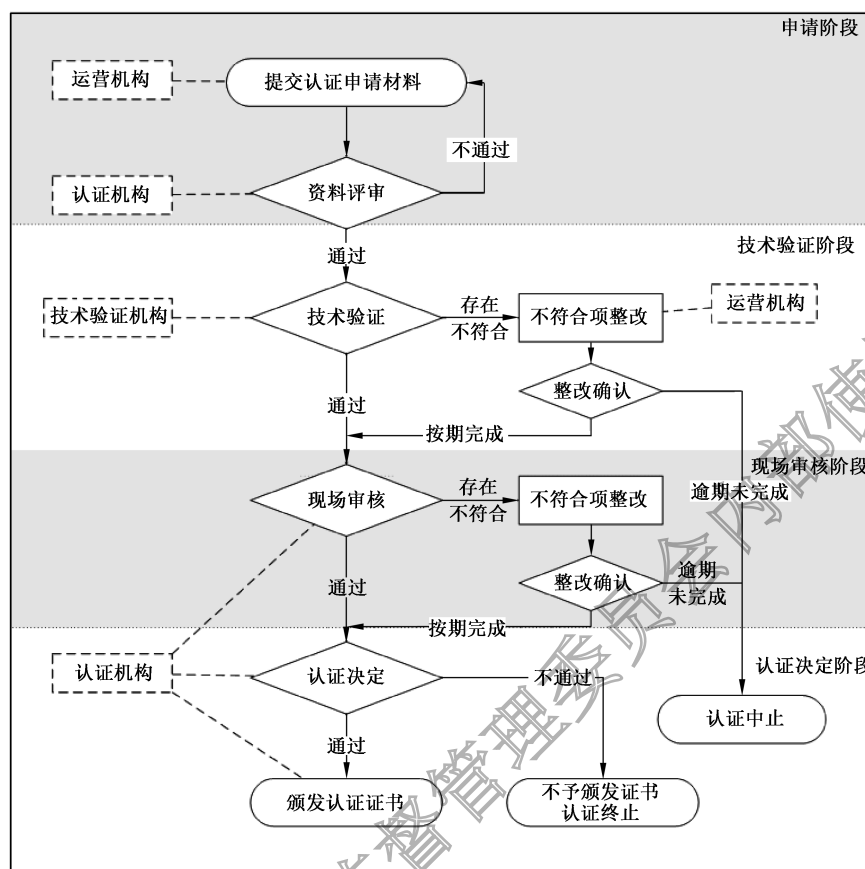


图 1 认证评价流程图

4.2 评价主要环节

4.2.1 文档审核

认证机构接收运营机构提交的申请材料。申请材料应能够证明当前业务情况满足或符合认证相关安全要求。包括但不限于：

- 认证申请书；
- 认证申请方资质证明；
- 认证授权书；
- 认证申请方承诺；
- 相关管理制度；
- 自我评价报告等其他可证明标准符合性文件；
- 其他需要的文件。

认证机构应对运营机构提交的资料和文档进行初步审核，确认文档是否完备。

4.2.2 技术验证

技术验证机构应依据 6.1~6.5 的要求对运营机构申请认证的 App 进行技术验证。技术验证通过后，应向运营机构出具经签字并盖章的技术验证报告，并向认证机构提供技术验证结果。技术验证报告应包括以下内容：

- a) App 名称、版本及运行环境；
- b) App 运营机构、开发机构及相关联系人信息；
- c) 技术验证工具及环境说明；
- d) 技术验证机构名称、测试人员、时间、地点；
- e) 技术验证内容、方法及依据；
- f) 技术验证结论。

4.2.3 现场审核

认证机构指派专业的审核员对运营机构提供的关于本文件 6.6 和 6.7 要求的相关记录及管理文件进行审核,包括但不限于以下文件。

- a) App 管理制度,至少包括:
 - 个人信息安全事件应急处置,
 - 人员管理及培训,
 - 安全审计,
 - 日志定期审核制度等方面内容。
- b) 个人信息处理活动相关记录或报告,包括:
 - 个人信息安全工程,
 - 个人信息处理活动记录,
 - 个人信息安全影响评估,
 - 数据安全能力等。

此外,为了保障认证的持续有效性,认证机构应对 App 运营环境和关键场所进行审核,审核内容包括但不限于:

- a) 文件审核中发现的需核实的问题;
- b) 管理制度落实情况;
- c) App 一致性检查。

5 评价要求

5.1 组建团队

认证机构和技术验证机构从事 App 个人信息安全评价工作时,应组建专业的评价人员团队,具体要求如下:

- a) 评价人员应涵盖个人信息保护、数据安全、信息安全等相关领域,且职责分工明确;
- b) 认证机构应组建审核组,审核组应设置审核组组长和组员;
- c) 技术验证机构应组建测试组,测试组应包含 1 名团队负责人、1 名质量负责人以及不少于 3 名的评价人员。

5.2 制定方案

认证机构和技术验证机构从事 App 个人信息安全评价工作时,应制定评价方案,具体要求如下:

- a) 评价方案内容应涵盖评价对象、评价依据、评价过程、评价内容、评价方法和评价计划等;
- b) 评价方案编制完成后,评价人员应针对方案内容与运营机构进行确认,并依据确认后的方案实施评价。

5.3 实施评价

认证机构和技术验证机构实施 App 个人信息安全评价工作时,具体要求如下:

- a) 评价人员应按照第 4 章评价流程,依据 5.2 制定的评价方案开展评价工作;
- b) 评价内容及方法应与第 6 章一致,具体评价内容应符合附录 A;

注:评价项编码规则说明参见附录 B。

- c) 评价过程应公平、公正和规范。

5.4 结果记录

认证机构和技术验证机构从事 App 个人信息安全评价工作时,具体要求如下:

- a) 评价人员应及时、完整、清晰地记录评价结果;
- b) 经评价人员和审核人员签名后,禁止更改、增删评价记录;
- c) 完成评价后,评价人员应出具正式的评价报告,包括但不限于技术验证报告、现场审核报告等;
- d) 评价人员应妥善留存评价结论相关的证明材料,以确保评价结果可追溯、可复现。

6 评价内容及方法

6.1 个人信息的收集

6.1.1 收集个人信息的合法性

6.1.1.1 A1-TEC-001

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.1a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否存在以不正当方式收集个人信息的情况;
 - 2) 检查个人信息控制者是否具备完善的管理制度明确要求 App 不以欺诈、诱骗、误导的方式收集个人信息。
- c) 判定准则:如果 1)为否定且 2)为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.1.2 A1-TEC-002

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.1b)的要求。
- b) 评价方法:
 - 1) 测试 App 是否存在隐瞒收集个人信息的功能;
 - 2) 测试 App 是否存在业务功能隐瞒收集个人信息的行为。
- c) 判定准则:如果 1)和 2)均为否定,则符合本评价项要求;否则不符合本评价项要求。

6.1.1.3 A1-TEC-003

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.1c)的要求。

- b) 评价方法:检查个人信息控制者是否从非法渠道间接获取(共享、转让及公开搜索等方式)个人信息。
- c) 判定准则:以上评价结果为否定,则符合本评价项要求;否则不符合本评价项要求。

6.1.2 收集个人信息的最小必要

6.1.2.1 A2-TEC-004

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.2a)的要求。
- b) 评价方法:测试 App 是否存在收集与业务功能无关的个人信息。
- c) 判定准则:以上评价结果为否定,则符合本评价项要求;否则不符合本评价项要求。

6.1.2.2 A2-TEC-005

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.2b)的要求。
- b) 评价方法:测试 App 自动采集个人信息的频率是否合理。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.2.3 A2-TEC-006

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.2c)的要求。
- b) 评价方法:询问并验证个人信息控制者间接获取个人信息的数量是否为实现产品或服务的业务功能所必需的最少数量。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.3 多项业务功能的自主选择

6.1.3.1 A3-TEC-007

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.3a)的要求。
- b) 评价方法:测试 App 是否存在要求个人信息主体一次性接受并授权同意收集个人信息的多个请求。
- c) 判定准则:以上评价结果为否定,则符合本评价项要求;否则不符合本评价项要求。

6.1.3.2 A3-TEC-008

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.3b)的要求。
- b) 评价方法:
 - 1) 使用 App 并测试其是否将个人信息主体自主选择行为(如通过主动点击、勾选、填写等方式)作为开启特定业务功能的条件;
 - 2) App 收集与业务功能有关的非必要信息时,测试 App 是否经用户自主选择同意。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.3.3 A3-TEC-009

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.3c)的要求。
- b) 评价方法:
 - 1) 检查个人信息主体能否自主选择关闭或退出特定业务功能,同时关闭或退出的途径是否与开启同样方便;
 - 2) 检查某特定功能退出后是否停止个人信息收集。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.3.4 A3-TEC-010

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.3d)的要求。
- b) 评价方法:测试 App 在关闭或退出特定业务功能后是否存在频繁打扰。
- c) 判定准则:以上评价结果为否定,则符合本评价项要求;否则不符合本评价项要求。

6.1.3.5 A3-TEC-011

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.3e)的要求。
- b) 评价方法:测试 App 在关闭或退出特定业务功能时,是否影响其他业务功能。
- c) 判定准则:以上评价结果为否定,则符合本评价项要求;否则不符合本评价项要求。

6.1.3.6 A3-TEC-012

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.3f)的要求。
- b) 评价方法:测试 App 是否存在仅以改善服务质量、提升使用体验、研发新产品、增强安全性等为由,强制要求个人信息主体同意收集个人信息。
- c) 判定准则:以上评价结果为否定,则符合本评价项要求;否则不符合本评价项要求。

6.1.4 收集个人信息时的授权同意

6.1.4.1 A4-TEC-013

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.4a)的要求。
- b) 评价方法:测试 App 在收集个人信息之前,是否向用户告知收集、使用个人信息的目的、方式和范围等规则,并征得个人信息主体的授权同意。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.4.2 A4-TEC-014

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.4b)的要求。

- b) 评价方法:测试 App 在收集个人敏感信息前,是否征得个人信息主体的明示同意。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.4.3 A4-TEC-015

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.4c)的要求。
- b) 评价方法:
 - 1) 测试 App 是否收集个人生物识别信息,如收集,则判断 2)和 3);
 - 2) 检查 App 收集个人生物识别信息前,是否单独向个人信息主体告知收集、使用个人生物识别信息的目的、方式和范围,以及存储时间等规则;
 - 3) 检查 App 在收集个人生物识别信息前,是否征得个人信息主体的明示同意。
- c) 判定准则:如果 1)、2)和 3)均为肯定,则符合本评价项要求;如果 1)为肯定,2)或 3)为否定,则不符合本评价项要求。如果 1)为否定,则本评价项为不适用。

6.1.4.4 A4-TEC-016

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.4d)的要求。
- b) 评价方法:
 - 1) 检查 App 是否涉及收集未成年人的个人信息,如涉及,则判断 2)和 3);
 - 2) 测试 App 在收集不满 14 周岁未成年人的个人信息前,是否征得其监护人的明示同意;
 - 3) 测试 App 在收集年满 14 周岁未成年人的个人信息前,是否征得未成年人或其监护人的明示同意。
- c) 判定准则:如果 1)、2)和 3)均为肯定,则符合本评价项要求;如果 1)为肯定,2)或 3)为否定,则不符合本评价项要求。如果 1)为否定,则本评价项为不适用。

6.1.4.5 A4-TEC-017

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.4e)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否存在间接获取个人信息,如存在,则判断 2)、3)和 4);
 - 2) 检查个人信息控制者间接获取个人信息的来源是否合法,并验证其合法性;
 - 3) 检查个人信息控制者是否掌握个人信息提供方已获得的个人信息处理的授权范围(包括使用目的、个人信息主体是否授权同意转让、共享、公开披露、删除等);
 - 4) 如超过原授权范围,检查个人信息控制者是否重新征得个人信息主体的明示同意或通过个人信息提供方征得个人信息主体的明示同意。
- c) 判定准则:如果 1)、2)、3)、4)均为肯定,则符合本评价项要求;如果 1)为肯定,2)或 3)或 4)为否定,不符合本评价项要求。如果 1)为否定,则本评价项为不适用。

6.1.5 个人信息保护政策

6.1.5.1 A5-TEC-018

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.5a)的要求。
- b) 评价方法:
 - 1) 查看 App 是否制定单独成文的个人信息保护政策;
 - 2) 检查 App 的个人信息保护政策是否完整说明收集使用个人信息规则,规则内容涉及要素至少包括:
 - 个人信息控制者的基本信息,包括主体身份、责任人姓名及联系方式;
 - 收集、使用个人信息的业务功能,以及各业务功能分别收集的个人信息类型;
 - 涉及个人敏感信息的,是否明确标识或突出显示;
 - 收集使用个人信息的目的、方式、类型、数量、频率、范围等;
 - 个人信息存储地点、期限以及到期后的处理方式;
 - 涉及数据出境情况等个人信息处理规则;
 - 对外共享、转让、公开披露个人信息的目的、涉及的个人信息类型、接收个人信息的第三方类型,以及各自的安全和法律责任;
 - 个人信息主体查询、更正、删除、撤销同意、获取个人信息副本、对信息系统自动决策结果申诉的权利和实现机制;
 - 提供个人信息后可能存在的安全风险,以及不提供个人信息可能产生的影响;
 - 遵循的个人信息安全基本原则,具备的数据安全能力,以及采取的个人信息安全保护措施;
 - 处理个人信息主体询问、投诉的渠道和机制,以及外部纠纷解决机构及联络方式;
 - 是否说明当前版本发布、生效或更新日期以及更新后的告知方式。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.5.2 A5-TEC-019

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.5b)的要求。
- b) 评价方法:测试 App 个人信息保护政策所告知的信息是否真实、准确、完整。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.5.3 A5-TEC-020

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.5c)的要求。
- b) 评价方法:检查 App 个人信息保护政策的内容是否清晰易懂、易于阅读。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.5.4 A5-TEC-021

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.5d)的要求。
- b) 评价方法:测试 App 个人信息保护政策文本是否公开发布且易于访问。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.5.5 A5-TEC-022

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.5e)的要求。
- b) 评价方法:测试 App 个人信息保护政策是否逐一送达个人信息主体。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.5.6 A5-TEC-023

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.5f)的要求。
- b) 评价方法:在 5.5a)所载事项发生变化时,检查个人信息控制者是否及时更新了个人信息保护政策并重新告知了个人信息主体。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.1.6 征得授权同意的例外

6.1.6.1 A6-TEC-024

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 5.6a)~k)的要求。
- b) 评价方法:
 - 1) 检查个人信息保护政策是否告知征得个人信息主体授权同意的例外情形,如有,则判断 2);
 - 2) 检查被告知的征得同意例外情形是否超出标准的要求。
- c) 判定准则:
 - 如果 1)为肯定且 2)为否定,则符合本评价项要求;如果 1)、2)均为肯定,则不符合本评价项要求。如果 1)为否定,则本评价项为不适用。

6.2 个人信息的存储

6.2.1 个人信息存储时间最小化

6.2.1.1 B1-TEC-025

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 6.1a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者针对个人信息和个人敏感信息是否分别设立存储期限;
 - 2) 检查存储期限是否满足国家法律法规相关规定且为该业务实现所必需的最短存储期限;
 - 3) 检查是否存在相关的制度文件,且有相关处理的日志记录。
- c) 判定准则:如果 1)、2)和 3)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.2.1.2 B1-TEC-026

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 6.1b)的要求。

- b) 评价方法：
 - 1) 检查是否建立针对超期数据处理手段；
 - 2) 检查是否存在针对超期数据进行去标识化或删除处理的记录；
 - 3) 检查是否有相关处理的日志记录。
- c) 判定准则：如果 1)、2)和 3)均为肯定，则符合本评价项要求；否则不符合本评价项要求。

6.2.2 去标识化处理

6.2.2.1 B2-TEC-027

该评价项的内容和方法如下。

- a) 评价依据：应符合 GB/T 35273—2020 6.2 的要求。
- b) 评价方法：
 - 1) 收集个人信息后，检查个人信息控制者是否对个人信息进行了去标识化处理；
 - 2) 检查个人信息控制者针对收集的个人信息，是否设立了去标识化处理管理制度，将去标识化后的信息与可用于恢复识别个人的信息分开存储；
 - 3) 检查个人信息控制者针对收集的个人信息，是否采取的技术存储措施，将去标识化后的信息与可用于恢复识别个人的信息分开存储。
- c) 判定准则：

如果 1)、2)和 3)均为肯定，则符合本评价项要求；否则不符合本评价项要求。

注：因对应的评价要求为推荐性要求，本评价项为推荐项。

6.2.3 个人敏感信息的传输和存储

6.2.3.1 B3-TEC-028

该评价项的内容和方法如下。

- a) 评价依据：应符合 GB/T 35273—2020 6.3a)的要求。
- b) 评价方法：
 - 1) 针对个人敏感信息的传输，检查个人信息控制者是否采用加密等安全措施；
 - 2) 针对个人敏感信息的存储，检查个人信息控制者是否采用加密等安全措施。
- c) 判定准则：如果 1)和 2)均为肯定，则符合本评价项要求；否则不符合本评价项要求。如果 App 不涉及传输和存储个人敏感信息，则本评价项为不适用。

6.2.3.2 B3-TEC-029

该评价项的内容和方法如下。

- a) 评价依据：应符合 GB/T 35273—2020 6.3b)的要求。
- b) 评价方法：
 - 1) 检查 App 是否涉及存储个人生物识别信息，如有，则判断 2)；
 - 2) 如存储个人生物识别信息，检查是否与个人身份信息分开存储。
- c) 判定准则：如果 1)、2)为肯定，则符合本评价项要求；如果 2)为否定，则不符合本评价项要求。如果 1)为否定，则本评价项为不适用。

6.2.3.3 B3-TEC-030

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 6.3c)的要求。
- b) 评价方法:
 - 1) 检查 App 是否涉及存储个人生物识别信息,如有,则判断 2);
 - 2) 如存储个人生物识别信息,检查是否采用相关措施确保信息安全后再进行存储,可采取的措施包括但不限于:
 - 仅存储个人生物识别信息的摘要信息;
 - 在采集终端中直接使用个人生物识别信息实现身份识别、认证等功能;
 - 在使用面部识别特征、指纹、掌纹、虹膜等实现识别身份、认证等功能后删除可提取个人生物识别信息的原始图像。
- c) 判定准则:如果 1)、2)为肯定,则符合本评价项要求;如果 1)为肯定且 2)为否定,则不符合本评价项要求。如果 1)为否定,则本评价项为不适用。

6.2.4 个人信息控制者停止运营

6.2.4.1 B4-TEC-031

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 6.4a)的要求。
- b) 评价方法:检查个人信息控制者是否建立停止运营产品或服务后的管理制度和流程以确保停止运营后及时停止继续收集个人信息。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.2.4.2 B4-TEC-032

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 6.4b)的要求。
- b) 评价方法:检查个人信息控制者是否具备相关管理制度或文档以说明个人信息控制者运营其产品或服务时将停止运营的通知以逐一送达或以公告的形式通知个人信息主体。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.2.4.3 B4-TEC-033

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 6.4c)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立关于停止运营产品或服务时对所持有个人信息进行删除或匿名化处理的管理规定;
 - 2) 检查个人信息控制者是否有关于停止运营产品或服务时对所持有个人信息进行删除或匿名化处理的流程。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.3 个人信息的使用

6.3.1 个人信息访问控制措施

6.3.1.1 C1-TEC-034

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.1a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立访问控制策略;
 - 2) 检查访问控制策略是否体现最少授权,如仅能访问职责所需的最少且够用的个人信息;
 - 3) 检查是否采用有效的技术措施实现最小授权机制;
 - 4) 检查是否存在相应的记录,如针对临时授权所应具备的访问时效和访问权限。
- c) 判定准则:如果 1)、2)、3)和 4)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.3.1.2 C1-TEC-035

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.1b)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否对个人信息的重要操作设置了内部审批流程;
 - 2) 检查个人信息控制者针对审批流程是否存在相应的记录。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.3.1.3 C1-TEC-036

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.1c)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否对安全管理人员、数据操作人员、审计人员的角色进行分离设置;
 - 2) 检查个人信息控制者是否存在相应的管理制度和角色控制设置记录。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.3.1.4 C1-TEC-037

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.1d)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立超权限处理个人信息的规定或流程设置;
 - 2) 检查个人信息控制者是否由个人信息保护责任人或个人信息保护工作机构对超权限处理个人信息行为进行审批;
 - 3) 检查个人信息控制者针对越权处理是否存在相应的记录。
- c) 判定准则:如果 1)、2)、3)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.3.1.5 C1-TEC-038

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.1e)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者对个人敏感信息的访问、修改等操作行为,是否在对角色的权限控制的基础上,根据业务流程的需求触发操作授权;
 - 2) 检查个人信息控制者是否存在相应的记录。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

注:因对应的评价要求为推荐性要求,本评价项为推荐项。

6.3.2 个人信息展示控制

6.3.2.1 C2-TEC-039

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.2 的要求。
- b) 评价方法:涉及通过界面展示个人信息的(如显示屏幕、纸面),个人信息控制者是否对需展示的个人采取去标识化处理等措施。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

注:因对应的评价要求为推荐性要求,本评价项为推荐项。

6.3.3 个人信息使用的目的限制

6.3.3.1 C3-TEC-040

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.3a)的要求。
- b) 评价方法:
 - 1) 个人信息控制者使用个人信息时,检查是否存在超出与收集个人信息时所声称的目的具有直接或合理关联的范围;
 - 2) 因业务需要,确需超出上述范围使用个人信息的,检查个人信息控制者是否再次征得个人信息主体明示同意。
- c) 判定准则:如果 1)为否定或者 1)、2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.3.3.2 C3-TEC-041

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.3b)的要求。
- b) 评价方法:对所收集的个人信息进行加工处理而产生的信息,能够单独或与其他信息结合识别自然人个人身份,或者反映自然人个人活动情况的,检查个人信息控制者是否遵循收集时获得的授权同意范围。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.3.4 用户画像的使用限制

6.3.4.1 C4-TEC-042

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.4a)的要求。
- b) 评价方法:
 - 1) 检查用户画像描述中是否包含淫秽、色情、赌博、迷信、恐怖、暴力的内容;
 - 2) 检查用户画像描述中是否表达对民族、种族、宗教、残疾、疾病歧视等内容。
- c) 判定准则:如果 1)和 2)均为否定,则符合本评价项要求;否则不符合本评价项要求。

6.3.4.2 C4-TEC-043

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.4b)的要求。
- b) 评价方法:
 - 1) 检查用户画像的使用是否涉及侵害公民、法人和其他组织的合法权益;
 - 2) 检查用户画像的使用是否危害国家安全、荣誉和利益,煽动颠覆国家政权、推翻社会主义制度,煽动分裂国家、破坏国家统一,宣扬恐怖主义、极端主义,宣扬民族仇恨、民族歧视,传播暴力、淫秽色情信息,编造、传播虚假信息扰乱经济秩序和社会秩序等内容。
- c) 判定准则:如果 1)和 2)均为否定,则符合本评价项要求;否则不符合本评价项要求。

6.3.4.3 C4-TEC-044

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.4c)的要求。
- b) 评价方法:
 - 1) 检查用户画像是否用于非个人信息主体授权的场景;
 - 2) 检查是否把能够精准定位到个人的用户画像用于推送商业广告。
- c) 判定准则:如果 1)和 2)均为否定,则符合本评价项要求;否则不符合本评价项要求。

6.3.5 个性化展示及退出

6.3.5.1 C5-TEC-045

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.5a)的要求。
- b) 评价方法:
 - 1) 检查 App 是否向个人信息主体提供个性化展示服务,如有,则判断 2);
 - 2) 当 App 提供个性化展示时,检查 App 是否显著区分(显著区分的方式包括但不限于:标明“定推”等字样,或通过不同的栏目、板块、页面分别展示等)个性化展示的内容和非个性化展示的内容。
- c) 判定准则:如果 1)、2)为肯定,则符合本评价项要求;如果 1)为肯定且 2)为否定,则不符合本评价项要求。如果 1)为否定,则本评价项为不适用。

6.3.5.2 C5-TEC-046

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.5b)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制是否向个人信息主体提供电子商务服务,如有,则判断 2);
 - 2) 当个人信息控制者根据消费者的兴趣爱好、消费习惯等特征向其提供商品或者服务搜索结果的个性化展示时,检查是否同时对该消费者提供不针对其个人特征的选项。
- c) 判定准则:如果 1)、2)为肯定,则符合本评价项要求;如果 1)为肯定且 2)为否定,则不符合本评价项要求。如果 1)为否定,则本评价项为不适用。

6.3.5.3 C5-TEC-047

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.5c)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否在向个人信息主体推送新闻信息服务过程中使用个性化展示,如有,则判断 2)和 3);
 - 2) 当个人信息控制者向个人信息主体推送新闻信息服务过程中使用个性化展示时,检查 App 是否提供简单直观的退出或关闭个性化展示模式的选项;
 - 3) 当个人信息主体选择退出或关闭个性化展示模式时,检查 App 是否向个人信息主体提供删除或匿名化定向推送活动所基于的个人信息选项。
- c) 判定准则:如果 1)、2)、3)为肯定,则符合本评价项要求;如果 1)为肯定、2)或 3)为否定,则不符合本评价项要求。如果 1)为否定,则本评价项为不适用。

6.3.5.4 C5-TEC-048

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.5d)的要求。
- b) 评价方法:检查个人信息控制者是否建立个人信息主体对个性化展示所依赖的个人信息(如标签、画像维度等)的自主控制机制,保障个人信息主体调控个性化展示相关程度的能力。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

注:因对应的评价要求为推荐性要求,本评价项为推荐项。

6.3.6 基于不同业务目的所收集的个人信息汇聚融合

6.3.6.1 C6-TEC-049

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.6a)的要求。
- b) 评价方法:对于基于不同业务目的所收集的个人信息的汇聚融合,检查个人信息控制者是否遵循 GB/T 35273 7.3.3 的要求。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.3.6.2 C6-TEC-050

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.6b)的要求。
- b) 评价方法:
 - 1) 根据汇聚融合后个人信息所用于的目的,检查个人信息控制者是否开展个人信息安全影响评估,采取适当的个人信息保护措施;
 - 2) 检查个人信息控制者是否存在相应的记录。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.3.7 信息系统自动决策机制的使用

6.3.7.1 C7-TEC-051

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.7a)的要求。
- b) 评价方法:检查个人信息控制者是否在规划设计阶段或首次使用前开展个人信息安全影响评估,并依评估结果采取有效的保护个人信息主体的措施。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.3.7.2 C7-TEC-052

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.7b)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否在使用过程中定期(至少每年一次)开展个人信息安全影响评估,并依评估结果改进保护个人信息主体的措施;
 - 2) 检查个人信息控制者是否存在相应的记录。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.3.7.3 C7-TEC-053

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 7.7c)的要求。
- b) 评价方法:检查个人信息控制者是否向个人信息主体提供针对自动决策结果的申诉渠道,并对自动决策结果进行人工复核。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4 个人信息主体的权利

6.4.1 个人信息查询

6.4.1.1 D1-TEC-054

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.1a)的要求。

- b) 评价方法:检查个人信息控制者是否提供查询其所持有的关于该主体的个人信息或个人信息的类型的方法。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.1.2 D1-TEC-055

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.1b)的要求。
- b) 评价方法:检查个人信息控制者是否提供查询其所持有的关于该主体的个人信息来源及所用于目的的方法。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.1.3 D1-TEC-056

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.1c)的要求。
- b) 评价方法:检查个人信息控制者是否提供查询其已经获得上述个人信息的第三方身份或类型。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.2 个人信息更正

6.4.2.1 D2-TEC-057

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.2 的要求。
- b) 评价方法:检查个人信息控制者是否提供更正个人信息的有效方式。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.3 个人信息删除

6.4.3.1 D3-TEC-058

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.3a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否为用户提供删除个人信息的有效方式;
 - 2) 违反法律法规规定或违反与用户的约定,收集、使用个人信息的,检查个人信息控制者是否按照用户的要求删除个人信息。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.3.2 D3-TEC-059

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.3b)的要求。
- b) 评价方法:违反法律法规规定或违反与用户的约定,向第三方共享、转让个人信息的,检查个人信息控制者是否按照用户要求,立即停止共享、转让的行为,并通知第三方及时删除。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.3.3 D3-TEC-060

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.3c)的要求。
- b) 评价方法:违反法律法规规定或违反与个人信息主体的约定,公开披露个人信息的,检查个人信息控制者是否按照用户要求,立即停止公开披露的行为,并发布通知要求相关接收方删除相应的信息。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.4 个人信息主体撤回同意

6.4.4.1 D4-TEC-061

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.4a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否向用户提供撤回收集、使用同意授权其个人信息的方法;
 - 2) 撤回授权后,检查个人信息控制者是否不再处理个人信息。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.4.2 D4-TEC-062

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.4b)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否提供用户拒绝接收基于其个人信息推送的商业广告的方法;
 - 2) 涉及对外共享、转让、公开披露个人信息时,检查个人信息控制者是否向用户提供撤回同意的的方法。
- c) 判定准则:如果 1)为肯定、2)为不适用,或者 1)、2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.5 个人信息主体注销账户

6.4.5.1 D5-TEC-063

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.5a)的要求。
- b) 评价方法:检查个人信息控制者是否向用户提供注销账户的方法,且方法简便易操作。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.5.2 D5-TEC-064

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.5b)的要求。
- b) 评价方法:检查个人信息控制者受理注销账户请求后需要人工处理时,是否在承诺时限内(不超过 15 个工作日)完成核查和处理。

- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.5.3 D5-TEC-065

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.5c)的要求。
- b) 评价方法:注销过程如需身份验证时,检查个人信息控制者要求个人信息主体再次提供的个人信息类型是否多于注册、使用等服务环节收集的个人信息类型。
- c) 判定准则:以上评价结果为否定,则符合本评价项要求;否则不符合本评价项要求。

6.4.5.4 D5-TEC-066

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.5d)的要求。
- b) 评价方法:检查验证注销过程是否设置不合理的条件或提出额外要求增加个人信息主体义务,如注销单个账户视同注销多个产品或服务,要求个人信息主体填写精确的历史操作记录作为注销的必要条件。
- c) 判定准则:以上评价结果为否定,则符合本评价项要求;否则不符合本评价项要求。

6.4.5.5 D5-TEC-067

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.5e)的要求。
- b) 评价方法:
 - 1) 检查注销过程是否涉及收集个人敏感信息以核验身份;
 - 2) 当注销账户需收集个人敏感信息核验身份时,检查个人信息控制者是否明确对收集个人敏感信息后的处理措施,如达成目的后立即删除或匿名化处理。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;如果 1)为肯定且 2)为否定,则不符合本评价项要求。如果 1)为否定,则本评价项为不适用。

6.4.5.6 D5-TEC-068

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.5f)的要求。
- b) 评价方法:
 - 1) 在用户注销账户后,检查个人信息控制者是否及时删除其个人信息或作匿名化处理;
 - 2) 检查个人信息控制者是否具有相关日志信息。
- c) 判定准则:如果 1)和 2)均为符合,则符合本评价项要求;否则不符合本评价项要求。

6.4.6 个人信息主体获取个人信息副本

6.4.6.1 D6-TEC-069

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.6a)~b)的要求。
- b) 评价方法:

- 1) 检查个人信息控制者是否为用户提供获取个人信息副本的方法,或在技术可行的前提下能够直接将个人信息的副本传输给用户指定的第三方;
 - 2) 检查个人信息控制者提供的个人信息副本是否涵盖个人基本资料、个人身份信息、个人健康生理信息、个人教育工作信息等个人信息类型。
- c) 判定准则:如果 1)和 2)均为符合,则符合本评价项要求;否则不符合本评价项要求。

注:因对应的评价要求为推荐性要求,本评价项为推荐项。

6.4.7 响应个人信息主体的请求

6.4.7.1 D7-TEC-070

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.7a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否在 30 天内或法律法规规定的期限内做出答复及合理解释;
 - 2) 检查个人信息控制者是否告知个人信息主体外部纠纷解决途径;
 - 3) 检查个人信息控制者是否具有相关记录信息。
- c) 判定准则:如果 1)、2)和 3)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.7.2 D7-TEC-071

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.7b)的要求。
- b) 评价方法:检查个人信息控制者是否直接在产品或服务提供的功能界面中设置相应的机制,便于个人信息主体在线行使其访问、更正、删除、撤回同意、注销账户等权利。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

注:因对应的评价要求为推荐性要求,本评价项为推荐项。

6.4.7.3 D7-TEC-072

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.7c)的要求。
- b) 评价方法:检查个人信息控制者是否对合理的且在一定时期内多次重复的请求收取成本费用。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.7.4 D7-TEC-073

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.7d)的要求。
- b) 评价方法:当直接实现个人信息主体的请求需要付出高额的成本或存在其他显著的困难,检查个人信息控制者是否向个人信息主体提供其他替代性方法,以保护个人信息主体的合法权益。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.7.5 D7-TEC-074

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.7e)的要求。
- b) 评价方法:检查个人信息控制者是否在隐私条款等相关文件中明确可不响应个人信息主体基于 GB/T 35273—2020 8.1~8.6 提出的请求。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.7.6 D7-TEC-075

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.7f)的要求。
- b) 评价方法:检查个人信息控制者决定不响应个人信息主体请求时,是否向个人信息主体告知做出该决定的理由,同时是否向个人信息主体提供投诉的途径。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.4.8 申诉管理

6.4.8.1 D8-TEC-076

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 8.8 的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立申诉管理制度;
 - 2) 检查个人信息控制者是否提供了有效的申诉渠道;
 - 3) 检查个人信息控制者是否承诺了反馈时限;
 - 4) 检查个人信息控制者是否在承诺的反馈时限内进行响应。
- c) 判定准则:如果 1)~4)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5 个人信息的委托处理、共享、转让、公开披露

6.5.1 委托处理

6.5.1.1 E1-TEC-077

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.1a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否针对委托行为建立了管理制度;
 - 2) 检查个人信息控制者在发生过的委托行为中,是否超出已征得个人信息主体授权同意的范围或是否遵守 GB/T 35273—2020 5.6 规定的情形。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.1.2 E1-TEC-078

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.1b)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否针对个人信息安全影响评估建立管理制度;

- 2) 检查个人信息控制者在发生过的委托行为中,是否对委托行为进行个人信息安全影响评估,确保受委托者达到 GB/T 35273—2020 11.5 规定的数据安全能力要求。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.1.3 E1-TEC-079

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.1c)的要求。
- b) 评价方法:
 - 1) 检查受委托者是否严格按照个人信息控制者的要求处理个人信息。如受委托者因特殊原因未按照个人信息控制者的要求处理个人信息,是否向个人信息控制者反馈;
 - 2) 检查受委托者再次委托时,是否事先征得个人信息控制者的授权;
 - 3) 检查受委托者是否协助个人信息控制者响应个人信息主体基于 GB/T 35273—2020 8.1~8.6 提出的请求;
 - 4) 检查受委托者在处理个人信息过程中能否提供足够的安全保护水平,或发生了安全事件,是否及时向个人信息控制者反馈;
 - 5) 检查受委托者在委托关系解除时,是否仍存储个人信息。
- c) 判定准则:如果 1)、2)、3)、4)和 5)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.1.4 E1-TEC-080

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.1d)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否通过合同等方式规定受托者的责任和义务;
 - 2) 检查个人信息控制者是否对受托者进行审计。
- c) 判定准则:如果 1)、2)为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.1.5 E1-TEC-081

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.1e)的要求。
- b) 评价方法:检查个人信息控制者是否准确记录和存储委托处理个人信息的情况。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.1.6 E1-TEC-082

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.1f)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立面对受委托者未按照委托要求或未能履行个人信息安全保护责任情况的处理机制;
 - 2) 检查个人信息控制者得知或发现受委托者未按照委托要求或未能履行个人信息安全保护责任的,是否要求受委托者停止相关行为,且采取或要求受委托者采取有效补救措施(如更改口令、回收权限、断开网络连接等)来控制或消除个人信息面临的安全风险;必要时个

人信息控制者应解除与受委托者的业务关系,并要求受委托者及时删除从个人信息控制者获得的个人信息。

- c) 判定准则:如果 1)、2)为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.2 个人信息共享、转让

6.5.2.1 E2-TEC-083

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.2a)的要求。
- b) 评价方法:
- 1) 检查个人信息控制者是否建立关于个人信息控制者共享、转让个人信息的管理制度;
 - 2) 检查个人信息控制者在共享转让个人信息前,是否开展了个人信息安全影响评估,并依据评估结果采取了有效的保护个人信息主体的措施。
- c) 判定准则:如果 1)和 2)均为符合,则符合本评价项要求;否则不符合本评价项要求。

6.5.2.2 E2-TEC-084

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.2b)的要求。
- b) 评价方法:
- 1) 检查个人信息控制者是否建立关于共享、转让个人信息的管理制度;
 - 2) 检查个人信息控制者在共享、转让个人信息前,是否告知个人信息主体共享、转让个人信息的目的、数据接收方的类型及可能产生的后果;
 - 3) 检查个人信息控制者在共享、转让个人信息前,是否征得了个人信息主体的授权同意。
- c) 判定准则:如果 1)~3)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.2.3 E2-TEC-085

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.2c)的要求。
- b) 评价方法:
- 1) 检查个人信息控制者是否有关于个人信息控制者共享、转让个人敏感信息的管理制度;
 - 2) 检查个人信息控制者在共享、转让个人敏感信息前,是否征得了个人信息主体的明示同意;
 - 3) 检查个人信息控制者是否告知了个人信息主体共享、转让个人敏感信息的目的、数据接收方的类型、个人敏感信息的类型、数据接收方的身份、数据安全能力及可能产生的后果。
- c) 判定准则:如果 1)~3)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.2.4 E2-TEC-086

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.2d)的要求。
- b) 评价方法:检查个人信息控制者是否通过合同等方式规定数据接收方的责任和义务。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.2.5 E2-TEC-087

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.2e)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立了关于共享、转让个人信息的管理制度;
 - 2) 检查个人信息控制者是否准确记录和存储个人信息的共享、转让的情况,包括共享、转让的日期、规模、目的,以及数据接收方基本情况等。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

注:因对应的评价要求为推荐性要求,本评价项为推荐项。

6.5.2.6 E2-TEC-088

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.2f)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立面对数据接收方违反法律法规要求或按双方约定处理个人信息的处理机制;
 - 2) 检查个人信息控制者发现数据接收方存在违反法律法规要求或双方约定处理个人信息的,是否要求数据接收方停止相关行为,且采取或要求数据接收方采取有效补救措施(如更改口令、回收权限、断开网络连接等)来控制或消除个人信息面临的安全风险;必要时个人信息控制者应解除与数据接收方的业务关系,并要求数据接收方及时删除从个人信息控制者处获得的个人信息。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.2.7 E2-TEC-089

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.2g)的要求。
- b) 评价方法:检查个人信息控制者是否有关于共享、转让个人信息的条款规定,以确保承担因共享、转让个人信息对个人信息主体合法权益造成损害的相应责任。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.2.8 E2-TEC-090

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.2h)的要求。
- b) 评价方法:检查个人信息控制者是否有关于共享、转让个人信息的管理制度,以帮助个人信息主体了解数据接收方对个人信息的存储、使用等情况,以及个人信息主体访问、更正、删除、注销账户等权利。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.2.9 E2-TEC-091

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.2i)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否存在共享、转让个人生物识别信息的行为;
 - 2) 检查个人信息控制者共享、转让个人生物识别信息前,是否单独向个人信息主体告知目的、个人生物识别信息的类型、数据接收方的具体身份和数据安全能力等;
 - 3) 检查个人信息控制者共享、转让个人生物识别信息前,是否征得个人信息主体的明示同意。
- c) 判定准则:如果 1)、2)和 3)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.3 收购、兼并、重组、破产时的个人信息转让

6.5.3.1 E3-TEC-092

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.3a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立了个人信息处理的管理制度,以明确在收购、兼并、重组、破产等变更发生时,应向个人信息主体告知有关情况;
 - 2) 检查个人信息控制者在发生过的收购、兼并、重组、破产行为中,是否向个人信息主体告知了有关情况。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.3.2 E3-TEC-093

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.3b)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者在收购、兼并、重组、破产等变更发生时,是否建立了个人信息处理的管理制度,以明确变更后的个人信息控制者应继续履行原个人信息控制者的责任和义务,如变更个人信息使用目的时,应重新取得个人信息主体的明示同意;
 - 2) 检查个人信息控制者在发生过的收购、兼并、重组、破产行为中,是否明确了变更后的个人信息控制者应继续履行原个人信息控制者的责任和义务,如变更个人信息使用目的时,是否重新取得个人信息主体的明示同意。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.3.3 E3-TEC-094

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.3c)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立了个人信息处理的管理制度,以明确当发生破产且无承接方时,个人信息控制者对数据采取的处理措施;
 - 2) 检查个人信息控制者发生破产且无承接方时,是否对数据做删除处理。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.4 个人信息公开披露

6.5.4.1 E4-TEC-095

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.4a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立了个人信息处理的管理制度,以明确在公开披露个人信息前,要开展个人信息安全影响评估;
 - 2) 检查个人信息控制者在发生过的个人信息公开披露行为中,是否开展个人信息安全影响评估,并依评估结果采取有效的保护个人信息主体的措施。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.4.2 E4-TEC-096

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.4b)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立了个人信息处理的管理制度,以明确应向个人信息主体告知公开披露个人信息的目的、类型,或事先未征得个人信息主体明示同意;
 - 2) 检查个人信息控制者在发生过的个人信息公开披露行为中,是否向个人信息主体告知公开披露个人信息的目的、类型,或事先是否征得个人信息主体明示同意。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.4.3 E4-TEC-097

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.4c)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立了个人信息处理的管理制度,以明确应向个人信息主体告知涉及的个人敏感信息的内容;
 - 2) 检查个人信息控制者在发生过的个人信息公开披露行为中,是否向个人信息主体告知涉及的个人敏感信息的内容。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.4.4 E4-TEC-098

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.4d)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立了个人信息处理的管理制度,以明确应记录和存储个人信息的公开披露的情况,包括公开披露的日期、规模、目的、公开范围等;
 - 2) 检查个人信息控制者在发生过的个人信息公开披露行为中,是否记录和存储了个人信息的公开披露的情况,包括公开披露的日期、规模、目的、公开范围等。

- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.4.5 E4-TEC-099

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.4e)的要求。
- b) 评价方法:检查个人信息控制者是否建立了个人信息处理的管理制度,以明确个人信息控制者在对个人信息主体合法权益造成损害时应承担相应责任。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.4.6 E4-TEC-100

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.4f)的要求。
- b) 评价方法:
- 1) 检查个人信息控制者是否建立了个人信息处理的管理制度,以明确不应公开披露个人生物识别信息;
 - 2) 检查个人信息控制者在发生过的个人信息公开披露行为中,是否存在公开披露个人生物识别信息的情况。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.4.7 E4-TEC-101

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.4g)的要求。
- b) 评价方法:
- 1) 检查个人信息控制者是否建立了个人信息处理的管理制度,以明确不应公开披露我国公民的种族、民族、政治观点、宗教信仰等个人敏感数据的分析结果;
 - 2) 检查个人信息控制者在发生过的个人信息公开披露行为中,是否存在公开披露我国公民的种族、民族、政治观点、宗教信仰等个人敏感数据的分析结果。
- c) 判定准则:如果 1)为肯定且 2)为否定,则符合本评价项要求;否则不符合本评价项要求。

6.5.5 共享、转让、公开披露个人信息时事先征得授权同意的例外

6.5.5.1 E5-TEC-102

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.5a)~g)的要求。
- b) 评价方法:
- 1) 检查个人信息控制者是否建立了管理制度或条款文件;
 - 2) 检查个人信息控制者是否存在未征得个人信息主体授权同意共享、转让、公开披露个人信息,且不在事先征得授权同意的例外范围的行为。
- c) 判定准则:如果 1)为肯定且 2)为否定,则符合本评价项要求;否则不符合本评价项要求。

6.5.6 共同个人信息控制者

6.5.6.1 E6-TEC-103

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.6a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否通过合同等形式与第三方共同确认应满足的个人信息安全要求;
 - 2) 检查个人信息控制者是否通过合同等形式与第三方共同确认在个人信息安全方面自身和第三方应分别承担的责任和义务;
 - 3) 检查个人信息控制者是否向个人信息主体明确告知以上内容。
- c) 判定准则:如果 1)、2)和 3)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.6.2 E6-TEC-104

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.6b)的要求。
- b) 评价方法:当个人信息控制者未向个人信息主体告知第三方身份,以及在个人信息安全方面自身和第三方应分别承担的责任和义务时,检查个人信息控制者是否承担因第三方引起的个人信息安全责任。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.7 第三方接入管理

6.5.7.1 E7-TEC-105

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.7a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立第三方产品或服务接入管理机制和工作流程;
 - 2) 检查个人信息控制者是否建立安全评估等机制设置接入条件。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.7.2 E7-TEC-106

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.7b)的要求。
- b) 评价方法:检查个人信息控制者是否与第三方产品或服务提供者通过合同等形式明确双方的安全责任及应实施的个人信息安全措施。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.7.3 E7-TEC-107

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.7c)的要求。

- b) 评价方法:检查个人信息控制者是否向个人信息主体明确标识产品或服务由第三方提供。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.7.4 E7-TEC-108

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.7d)的要求。
- b) 评价方法:检查个人信息控制者是否妥善留存第三方接入有关合同和管理记录。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.7.5 E7-TEC-109

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.7e)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否要求第三方根据本文件相关规定向个人信息主体征得收集个人信息的授权同意;
 - 2) 检查个人信息控制者是否核验了第三方实现本项要求的方式。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.7.6 E7-TEC-110

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.7f)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否要求第三方产品或服务建立响应个人信息主体请求、申诉等的机制;
 - 2) 检查个人信息控制者是否妥善留存、及时更新第三方产品或服务,建立响应个人信息主体请求、申诉等的机制。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.7.7 E7-TEC-111

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.7g)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否制定了第三方产品或服务的个人信息安全监督制度;
 - 2) 检查个人信息控制者在第三方产品或服务接入时,是否存在监督、整改、停止接入等相关行为。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.7.8 E7-TEC-112

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.7h)的要求。
- b) 评价方法:

- 1) 检查个人信息控制者是否对第三方嵌入或接入的自动化工具开展技术检测；
 - 2) 检查第三方嵌入或接入的自动化工具实际收集内容与约定内容是否一致；
 - 3) 检查个人信息控制者是否对第三方嵌入或接入的自动化工具来收集个人信息的行为进行审计,并在发现超出约定行为时及时切断接入；
 - 4) 检查第三方产品或服务接入管理制度中是否包含及时切断接入的内容。
- c) 判定准则:如果 1)、2)、3)和 4)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.5.8 个人信息跨境传输

6.5.8.1 E8-TEC-113

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 9.8 的要求。
- b) 评价方法:
 - 1) 检查个人信息保护政策中是否说明个人信息存储地点和跨境传输情况；
 - 2) 检查是否存在跨境传输行为,若存在,检查是否具有个人信息出境安全评估报告或其他证明文件。
- c) 判定准则:如果 1)、2)均为肯定,则符合本指标要求;否则不符合本评价项要求。

注:因对应的评价要求为推荐性要求,本评价项为推荐项。

6.6 个人信息安全事件处置

6.6.1 个人信息安全事件应急处置和报告

6.6.1.1 F1-MAG-114

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 10.1a)的要求。
- b) 评价方法:检查个人信息控制者是否制定个人信息安全事件应急预案。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.6.1.2 F1-MAG-115

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 10.1b)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否建立应急响应培训、应急演练相关规定；
 - 2) 检查是否按照规定的要求及频率(如至少每年一次)进行培训及演练。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.6.1.3 F1-MAG-116

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 10.1c)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否制定了安全事件告知要求；

- 2) 检查告知要求中是否明确了告知方式(邮件、信函、电话、推送通知等)和告知对象(受影响的个人信息主体);
- 3) 对于难以逐一告知,检查是否建立合理、有效的公开发布方式(网站公告、微信公告等)。
- c) 判定准则:如果 1)、2)和 3)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.6.1.4 F1-MAG-117

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 10.1d)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否设立对应急预案进行及时更新的规定;
 - 2) 检查更新依据是否包括相关法律法规变化、事件处置情况。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.6.2 安全事件告知

6.6.2.1 F2-MAG-118

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 10.2a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否制定了安全事件告知要求;
 - 2) 检查告知要求是否明确了告知方式(如邮件、信函、电话、推送通知等)和告知对象(受影响的个人信息主体);
 - 3) 对于难以逐一告知的情况,检查是否建立其他合理、有效的公开发布方式(如网站公告、微信公告等)。
- c) 判定准则:如果 1)、2)和 3)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.6.2.2 F2-MAG-119

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 10.2b)的要求。
- b) 评价方法:检查告知的内容是否完全包含以下内容:
 - 1) 安全事件的内容和影响;
 - 2) 已采取或将要采取的处置措施;
 - 3) 个人信息主体自主防范和降低风险的建议;
 - 4) 针对个人信息主体提供的补救措施;
 - 5) 个人信息保护负责人和个人信息保护工作机构的联系方式。
- c) 判定准则:如果 1)~5)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7 组织的个人信息安全管理要求

6.7.1 明确责任部门与人员

6.7.1.1 G1-MAG-120

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.1a)的要求。
- b) 评价方法:
 - 1) 检查管理制度中是否明确规定法定代表人或主要负责人对个人信息安全负全面领导责任;
 - 2) 检查规定的责任中是否包含人力、财力、物理保障相关责任。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.1.2 G1-MAG-121

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.1b)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否任命了个人信息保护负责人和个人信息保护机构;
 - 2) 检查所任命的个人信息保护负责人是否具有相关工作经历和专业背景;
 - 3) 检查个人信息处理活动的重要决策是否直接向组织主要负责人报告。
- c) 判定准则:如果 1)、2)和 3)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.1.3 G1-MAG-122

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.1c)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否满足以下规定条件之一:
 - 主要业务涉及个人信息处理,且从业人员规模大于 200 人;
 - 处理超过 100 万人的个人信息,或预计在 12 个月内预计处理超过 100 万人的个人信息;
 - 处理超过 10 万人的个人敏感信息。
 - 2) 满足以上条件之一的情况下,检查个人信息控制者是否设立专职的个人信息保护负责人和个人信息保护工作机构。
- c) 判定准则:如果 1)、2)为肯定,则符合本评价项要求;如果 1)为肯定且 2)为否定,则不符合本评价项要求。如果 1)否定,则本评价项为不适用。

6.7.1.4 G1-MAG-123

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.1d)的要求。
- b) 评价方法:检查制度、文件中所规定的个人信息保护负责人和个人信息保护工作机构职责是否覆盖 11.1d 款所规定的 1)~10)项内容。
- c) 判定准则:制度文件中未规定个人信息保护负责人和个人信息保护工作机构职责的,或者制度文件中规定的相关职责内容缺少 1)~10)条任一要素的,均不符合本评价项要求;否则符合本评价项要求。

6.7.1.5 G1-MAG-124

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.1e)的要求。
- b) 评价方法:检查个人信息控制者是否为个人信息保护负责人和个人信息保护工作机构提供必要的资源。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.2 个人信息安全工程

6.7.2.1 G2-MAG-125

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.2 的要求。
- b) 评价方法:检查个人信息控制者是否根据国家有关标准在需求、设计、开发、测试、发布等系统工程阶段考虑个人信息保护要求。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

注:因对应的评价要求为推荐性要求,本评价项为推荐项。

6.7.3 个人信息处理活动记录

6.7.3.1 G3-MAG-126

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.3a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否在制度、文件中明确要求建立、维护和更新所收集、使用的个人信息处理活动记录;
 - 2) 检查个人信息控制者是否存储了个人信息处理活动记录,并按规定进行维护和更新;
 - 3) 检查个人信息处理活动记录是否包含所涉及个人信息类别、数量、来源。
- c) 判定准则:如果 1)、2)和 3)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

注:因对应的评价要求为推荐性要求,本评价项为推荐项。

6.7.3.2 G3-MAG-127

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.3b)的要求。
- b) 评价方法:
 - 1) 检查个人信息处理活动记录是否区分个人信息处理目的和使用场景;
 - 2) 如涉及委托处理、共享、转让、公开披露或出境,检查个人信息控制者是否记录相关信息。
- c) 判定准则:如果 1)、2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

注:因对应的评价要求为推荐性要求,本评价项为推荐项。

6.7.3.3 G3-MAG-128

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.3c)的要求。
- b) 评价方法:检查个人信息处理活动记录中是否包含有关的信息系统、组织或人员。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

注：因对应的评价要求为推荐性要求，本评价项为推荐项。

6.7.4 开展个人信息安全影响评估

6.7.4.1 G4-MAG-129

该评价项的内容和方法如下。

- a) 评价依据：应符合 GB/T 35273—2020 11.4a) 的要求。
- b) 评价方法：检查个人信息控制者是否建立个人信息安全影响评估制度。
- c) 判定准则：以上评价结果为肯定，则符合本评价项要求；否则不符合本评价项要求。

6.7.4.2 G4-MAG-130

该评价项的内容和方法如下。

- a) 评价依据：应符合 GB/T 35273—2020 11.4b) 的要求。
- b) 评价方法：
 - 1) 检查个人信息控制者是否按制度开展了个人信息安全影响评估；
 - 2) 检查个人信息安全影响评估的内容是否覆盖规定的 6 个方面。
- c) 判定准则：如果 1) 和 2) 均为肯定，则符合本评价项要求；否则不符合本评价项要求。

6.7.4.3 G4-MAG-131

该评价项的内容和方法如下。

- a) 评价依据：应符合 GB/T 35273—2020 11.4c) 的要求。
- b) 评价方法：
 - 1) 检查个人信息安全影响评估制度中，是否有规定，产品或服务发布前，或功能发生重大变化时，需进行个人信息安全影响评估；
 - 2) 检查个人信息控制者是否有相应的评估记录。
- c) 判定准则：如果 1) 和 2) 均为肯定，则符合本评价项要求；否则不符合本评价项要求。

6.7.4.4 G4-MAG-132

该评价项的内容和方法如下。

- a) 评价依据：应符合 GB/T 35273—2020 11.4d) 的要求。
- b) 评价方法：
 - 1) 检查个人信息安全影响评估制度中是否有规定在法律法规有新的要求时，或在业务模式、信息系统、运行环境发生重大变更时，或发生重大个人信息安全事件时，应进行个人信息安全影响评估；
 - 2) 检查个人信息控制者是否有相应的评估记录。
- c) 判定准则：如果 1) 和 2) 均为肯定，则符合本评价项要求；否则不符合本评价项要求。

6.7.4.5 G4-MAG-133

该评价项的内容和方法如下。

- a) 评价依据：应符合 GB/T 35273—2020 11.4e) 的要求。
- b) 评价方法：

- 1) 检查个人信息控制者是否形成个人信息安全影响评估报告；
- 2) 检查个人信息控制者是否根据报告内容采取必要的个人信息安全保护措施。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.4.6 G4-MAG-134

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.4f)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否妥善留存个人信息安全影响评估报告；
 - 2) 检查个人信息控制者是否规定了相关方查阅或对外公开的方式或途径。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.5 数据安全能力

6.7.5.1 G5-MAG-135

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.5 的要求。
- b) 评价方法:检查个人信息控制者是否按照国家标准的要求,建立了适当的数据安全能力。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.6 人员管理与培训

6.7.6.1 G6-MAG-136

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.6a)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否有与个人信息处理岗位上的相关人员签署保密协议、对大量接触个人敏感信息的人员进行背景调查的规定；
 - 2) 检查并验证个人信息控制者是否按规定与从事个人信息处理岗位上的相关人员签署保密协议；
 - 3) 检查并验证个人信息控制者是否按规定对大量接触个人敏感信息的人员在入职之前进行背景审查。
- c) 判定准则:如果 1)、2)和 3)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.6.2 G6-MAG-137

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.6b)的要求。
- b) 评价方法:
 - 1) 检查个人信息控制者是否明确内部涉及个人信息处理不同岗位的安全职责；
 - 2) 检查个人信息控制者是否建立发生安全事件的处罚机制。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.6.3 G6-MAG-138

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.6c)的要求。
- b) 评价方法:检查是否规定个人信息处理岗位上的相关人员在调离岗位或终止劳动合同时继续履行保密义务。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.6.4 G6-MAG-139

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.6d)的要求。
- b) 评价方法:
 - 1) 检查是否明确对可能访问个人信息的外部服务人员规定了应遵守的个人信息安全要求;
 - 2) 检查是否与可能访问个人信息的外部服务人员签署保密协议、实施相应监督。
- c) 判定准则:如果 1)和 2)均为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.6.5 G6-MAG-140

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.6e)的要求。
- b) 评价方法:检查个人信息控制者是否对员工提出个人信息保护的指引和要求。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.6.6 G6-MAG-141

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.6f)的要求。
- b) 评价方法:检查个人信息控制者是否书面规定,定期(至少每年一次)或在个人信息保护政策发生重大变化时,对个人信息处理岗位上的相关人员开展个人信息安全专业化培训和考核。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.7 安全审计

6.7.7.1 G7-MAG-142

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.7a)的要求。
- b) 评价方法:检查个人信息控制者是否对个人信息保护政策、相关规程和安全措施的有效性进行审计。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.7.2 G7-MAG-143

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.7b)的要求。

- b) 评价方法:检查个人信息控制者是否建立自动化审计系统,监测记录个人信息处理活动。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.7.3 G7-MAG-144

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.7c)的要求。
- b) 评价方法:审计过程形成的记录是否能对安全事件的处置、应急响应和事后调查提供支撑。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.7.4 G7-MAG-145

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.7d)的要求。
- b) 评价方法:检查个人信息控制者是否采取了防止非授权的访问、篡改或删除审计记录的安全措施。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.7.5 G7-MAG-146

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.7e)的要求。
- b) 评价方法:检查个人信息控制者是否及时处理审计过程中发现的个人信息违规使用、滥用等情况。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

6.7.7.6 G7-MAG-147

该评价项的内容和方法如下。

- a) 评价依据:应符合 GB/T 35273—2020 11.7f)的要求。
- b) 评价方法:检查审计记录和留存时间是否符合相关法律法规的要求。
- c) 判定准则:以上评价结果为肯定,则符合本评价项要求;否则不符合本评价项要求。

7 评价结果判定

7.1 文档审核结果

认证机构对运营机构提交的资料和文档进行审核后做出受理决定,并向运营机构反馈受理结果。

7.2 技术验证结果判定

技术验证机构对 App 关于个人信息的收集、存储、使用、委托处理、共享、转让、公开披露以及个人信息主体的权利相关评价项进行技术验证并出具报告。技术验证报告中,除推荐性条款外其他所有评价项的评价结果均为符合时,技术验证结论为通过,反之为不通过。

7.3 现场审核结果判定

认证机构组织审核人员对 App 运营机构关于个人信息安全事件处置、组织的个人信息安全管理方

面进行现场审核并出具现场审核报告。现场审核报告中,除推荐性条款外其他所有评价项的评价结果均为符合时,现场审核结论为通过,反之为不通过。

7.4 认证决定

当文档审核、技术验证、现场审核结论均为通过时,进入认证决定环节。认证机构根据申请资料、技术验证结论和现场审核结论等进行综合评价,做出认证决定。认证决定通过后,由认证机构向运营机构颁发认证证书。认证决定不通过的,终止认证。

仅供国家认证认可监督管理委员会内部使用

附 录 A

(规范性)

移动智能终端应用软件个人信息安全评价内容

表 A.1 给出了移动智能终端应用软件个人信息安全评价内容。

表 A.1 移动智能终端应用软件个人信息安全评价内容

评价环节	评价内容	评价项编码	必检项	推荐项
技术验证	5.1 收集个人信息的合法性	5.1a)	A1-TEC-001	✓
		5.1b)	A1-TEC-002	✓
		5.1c)	A1-TEC-003	✓
	5.2 收集个人信息的最小必要	5.2a)	A2-TEC-004	✓
		5.2b)	A2-TEC-005	✓
		5.2c)	A2-TEC-006	✓
	5.3 多项业务功能的自主选择	5.3a)	A3-TEC-007	✓
		5.3b)	A3-TEC-008	✓
		5.3c)	A3-TEC-009	✓
		5.3d)	A3-TEC-010	✓
		5.3e)	A3-TEC-011	✓
		5.3f)	A3-TEC-012	✓
	5.4 收集个人信息时的授权同意	5.4a)	A4-TEC-013	✓
		5.4b)	A4-TEC-014	✓
		5.4c)	A4-TEC-015	✓
		5.4d)	A4-TEC-016	✓
		5.4e)	A4-TEC-017	✓
	5.5 个人信息保护政策	5.5a)	A5-TEC-018	✓
		5.5b)	A5-TEC-019	✓
		5.5c)	A5-TEC-020	✓
		5.5d)	A5-TEC-021	✓
		5.5e)	A5-TEC-022	✓
		5.5f)	A5-TEC-023	✓
	5.6 征得授权同意的例外	5.6a)~k)	A6-TEC-024	✓
	6.1 个人信息存储时间最小化	6.1a)	B1-TEC-025	✓
		6.1b)	B1-TEC-026	✓
	6.2 去标识化处理		B2-TEC-027	✓
	6.3 个人敏感信息的传输和存储	6.3a)	B3-TEC-028	✓
		6.3b)	B3-TEC-029	✓
		6.3c)	B3-TEC-030	✓

表 A.1 移动智能终端应用软件个人信息安全评价内容 (续)

评价环节	评价内容		评价项编码	必检项	推荐项
技术验证	6.4 个人信息控制者停止运营	6.4a)	B4-TEC-031	√	
		6.4b)	B4-TEC-032	√	
		6.4c)	B4-TEC-033	√	
	7.1 个人信息访问控制措施	7.1a)	C1-TEC-034	√	
		7.1b)	C1-TEC-035	√	
		7.1c)	C1-TEC-036	√	
		7.1d)	C1-TEC-037	√	
		7.1e)	C1-TEC-038		√
	7.2 个人信息的展示限制		C2-TEC-039		√
	7.3 个人信息使用的目的限制	7.3a)	C3-TEC-040	√	
		7.3b)	C3-TEC-041	√	
	7.4 用户画像的使用限制	7.4a)	C4-TEC-042	√	
		7.4b)	C4-TEC-043	√	
		7.4c)	C4-TEC-044	√	
	7.5 个性化展示的使用	7.5a)	C5-TEC-045	√	
		7.5b)	C5-TEC-046	√	
		7.5c)	C5-TEC-047	√	
		7.5d)	C5-TEC-048		√
	7.6 基于不同业务目的所收集的个人信息汇聚融合	7.6a)	C6-TEC-049	√	
		7.6b)	C6-TEC-050	√	
	7.7 信息系统自动决策机制的使用	7.7a)	C7-TEC-051	√	
		7.7b)	C7-TEC-052	√	
		7.7c)	C7-TEC-053	√	
	8.1 个人信息查询	8.1a)	D1-TEC-054	√	
		8.1b)	D1-TEC-055	√	
		8.1c)	D1-TEC-056	√	
	8.2 个人信息更正		D2-TEC-057	√	
	8.3 个人信息删除	8.3a)	D3-TEC-058	√	
		8.3b)	D3-TEC-059	√	
		8.3c)	D3-TEC-060	√	
	8.4 个人信息主体撤回同意	8.4a)	D4-TEC-061	√	
		8.4b)	D4-TEC-062	√	
	8.5 个人信息主体注销账户	8.5a)	D5-TEC-063	√	
		8.5b)	D5-TEC-064	√	
		8.5c)	D5-TEC-065	√	
		8.5d)	D5-TEC-066	√	
		8.5e)	D5-TEC-067	√	
		8.5f)	D5-TEC-068	√	

表 A.1 移动智能终端应用软件个人信息安全评价内容 (续)

评价环节	评价内容		评价项编码	必检项	推荐项
技术验证	8.6 个人信息主体获取个人信息副本	8.6a)~b)	D6-TEC-069		✓
	8.7 响应个人信息主体的请求	8.7a)	D7-TEC-070	✓	
		8.7b)	D7-TEC-071		✓
		8.7c)	D7-TEC-072	✓	
		8.7d)	D7-TEC-073	✓	
		8.7e)	D7-TEC-074		
		8.7f)	D7-TEC-075		
	8.8 申诉管理		D8-TEC-076	✓	
	9.1 委托处理	9.1a)	E1-TEC-077	✓	
		9.1b)	E1-TEC-078	✓	
		9.1c)	E1-TEC-079	✓	
		9.1d)	E1-TEC-080	✓	
		9.1e)	E1-TEC-081	✓	
		9.1f)	E1-TEC-082	✓	
	9.2 个人信息共享、转让	9.2a)	E2-TEC-083	✓	
		9.2b)	E2-TEC-084	✓	
		9.2c)	E2-TEC-085	✓	
		9.2d)	E2-TEC-086	✓	
		9.2e)	E2-TEC-087	✓	
		9.2f)	E2-TEC-088	✓	
		9.2g)	E2-TEC-089	✓	
		9.2h)	E2-TEC-090	✓	
		9.2i)	E2-TEC-091	✓	
	9.3 收购、兼并、重组、破产时的个人信息转让	9.3a)	E3-TEC-092	✓	
		9.3b)	E3-TEC-093	✓	
		9.3c)	E3-TEC-094	✓	
	9.4 个人信息公开披露	9.4a)	E4-TEC-095	✓	
		9.4b)	E4-TEC-096	✓	
		9.4c)	E4-TEC-097	✓	
		9.4d)	E4-TEC-098	✓	
		9.4e)	E4-TEC-099	✓	
		9.4f)	E4-TEC-100	✓	
		9.4g)	E4-TEC-101	✓	
	9.5 共享、转让、公开披露个人信息时事先征得授权同意的例外	9.5a)~g)	E5-TEC-102	✓	
	9.6 共同个人信息控制者	9.6a)	E6-TEC-103	✓	
		9.6b)	E6-TEC-104	✓	

表 A.1 移动智能终端应用软件个人信息安全评价内容（续）

评价环节	评价内容	评价项编码	必检项	推荐项
技术验证	9.7 第三方接入管理	9.7a)	E7-TEC-105	√
		9.7b)	E7-TEC-106	√
		9.7c)	E7-TEC-107	√
		9.7d)	E7-TEC-108	√
		9.7e)	E7-TEC-109	√
		9.7f)	E7-TEC-110	√
		9.7g)	E7-TEC-111	√
		9.7h)	E7-TEC-112	√
	9.8 个人信息跨境传输	E8-TEC-113	√	
现场审核	10.1 个人信息安全事件应急处置和报告	10.1a)	F1-MAG-114	√
		10.1b)	F1-MAG-115	√
		10.1c)	F1-MAG-116	√
		10.1d)	F1-MAG-117	√
	10.2 安全事件告知	10.2a)	F2-MAG-118	√
		10.2b)	F2-MAG-119	√
	11.1 明确责任部门与人员	11.1a)	G1-MAG-120	√
		11.1b)	G1-MAG-121	√
		11.1c)	G1-MAG-122	√
		11.1d)	G1-MAG-123	√
		11.1e)	G1-MAG-124	√
	11.2 个人信息安全工程	G2-MAG-125		√
	11.3 个人信息处理活动记录	11.3a)	G3-MAG-126	√
		11.3b)	G3-MAG-127	√
		11.3c)	G3-MAG-128	√
	11.4 开展个人信息安全影响评估	11.4a)	G4-MAG-129	√
		11.4b)	G4-MAG-130	√
		11.4c)	G4-MAG-131	√
		11.4d)	G4-MAG-132	√
		11.4e)	G4-MAG-133	√
		11.4f)	G4-MAG-134	√
	11.5 数据安全能力	G5-MAG-135	√	
	11.6 人员管理与培训	11.6a)	G6-MAG-136	√
		11.6b)	G6-MAG-137	√
		11.6c)	G6-MAG-138	√
		11.6d)	G6-MAG-139	√
		11.6e)	G6-MAG-140	√
		11.6f)	G6-MAG-141	√

表 A.1 移动智能终端应用软件个人信息安全评价内容（续）

评价环节	评价内容		评价项编码	必检项	推荐项
现场审核	11.7 安全审计	11.7a)	G7-MAG-142	√	
		11.7b)	G7-MAG-143	√	
		11.7c)	G7-MAG-144	√	
		11.7d)	G7-MAG-145	√	
		11.7e)	G7-MAG-146	√	
		11.7f)	G7-MAG-147	√	
注：以上评价内容对应 GB/T 35273—2020《信息安全技术 个人信息安全规范》各条款内容。					

附录 B
(资料性)
评价项编码规则说明

B.1 评价项编码规则

评价项编码格式为××-×××-×××，字符含义和编码规则如图 B.1 所示。

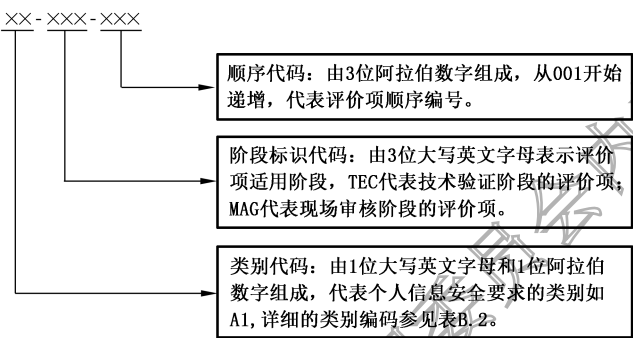


图 B.1 评价项编码规则说明

B.2 个人信息安全要求类别与代码

个人信息安全要求类别与类别代码对应关系见表 B.2。

表 B.2 个人信息安全要求类别代码对应表

类别代码	个人信息安全要求类别
A1	5.1 收集个人信息的合法性
A2	5.2 收集个人信息的最小必要
A3	5.3 多项业务功能的自主选择
A4	5.4 收集个人信息时的授权同意
A5	5.5 个人信息保护政策
A6	5.6 征得授权同意的例外
B1	6.1 个人信息存储时间最小化
B2	6.2 去标识化处理
B3	6.3 个人敏感信息的传输和存储
B4	6.4 个人信息控制者停止运营
C1	7.1 个人信息访问控制措施
C2	7.2 个人信息的展示限制
C3	7.3 个人信息使用的目的限制
C4	7.4 用户画像的使用限制

表 B.2 个人信息安全要求类别代码对应表（续）

类别代码	个人信息安全要求类别
C5	7.5 个性化展示的使用
C6	7.6 基于不同业务目的所收集个人信息的汇聚融合
C7	7.7 信息系统自动决策机制的使用
D1	8.1 个人信息查询
D2	8.2 个人信息更正
D3	8.3 个人信息删除
D4	8.4 个人信息主体撤回同意
D5	8.5 个人信息主体注销账号
D6	8.6 个人信息主体获取个人信息副本
D7	8.7 响应个人信息主体的请求
D8	8.8 投诉管理
E1	9.1 委托处理
E2	9.2 个人信息共享、转让
E3	9.3 收购、兼并、重组、破产时的个人信息转让
E4	9.4 个人信息公开披露
E5	9.5 共享、转让、公开披露个人信息时事先征得授权同意的例外
E6	9.6 共同个人信息控制者
E7	9.7 第三方接入管理
E8	9.8 个人信息跨境传输
F1	10.1 个人信息安全事件应急处置
F2	10.2 安全事件告知
G1	11.1 明确责任部门与人员
G2	11.2 个人信息安全工程
G3	11.3 个人信息处理活动记录
G4	11.4 开展个人信息安全影响评估 全管理要求
G5	11.5 数据安全能力
G6	11.6 人员管理与培训
G7	11.7 安全审计

参 考 文 献

- [1] GB/T 34975—2017 信息安全技术 移动智能终端应用软件 安全技术要求和测试评价方法
- [2] RB/T 072—2021 认证认可行业通用术语
- [3] 中华人民共和国数据安全法(2021年6月10日第十三届全国人民代表大会常务委员会第二十九次会议通过)
- [4] 中华人民共和国个人信息保护法(2021年8月20日第十三届全国人民代表大会常务委员会第三十次会议通过)
- [5] App违法违规收集使用个人信息行为认定方法(2019年12月30日国家互联网信息办公室、工业和信息化部、公安部、国家市场监督管理总局发布)